

Evolve — Deployment Readiness Report

Re-audit · React Native 0.80.2 + Firebase (Auth, Firestore, Storage, FCM, Cloud Functions) · Android `com.evolve` · iOS (bundle ID unset)

Audit date: 17 July 2026 (supersedes the report of the same date, pre-remediation) · Method: static code review + locally executed quality gates (tsc, ESLint, Jest ×3 projects, Firestore-emulator rules tests, npm audit) · Baseline commit: `cd3353e`

VERDICT: NOT READY — CONDITIONAL · 62 / 100 (was 34)

2

RELEASE BLOCKERS
was 7

3

HIGH SEVERITY
was 5

10

MEDIUM SEVERITY
was 9

8

LOW SEVERITY
was 7

0

TYPESCRIPT ERRORS
was 12

0

ESLINT ERRORS
was 24 · 5 warnings remain

136

TESTS PASSING
55 app + 49 Functions + 32
rules

0

CI/CD PIPELINES
unchanged

Executive summary

Since the previous audit earlier today, the team has landed a substantial remediation series (10 commits, `5e8c8fc...cd3353e`). **Five of the seven original release blockers are fixed and verified:** the Firestore rules now enforce the admin/superadmin permission matrix (confirmed by 32 passing emulator tests), the two broken admin Cloud Functions accept both admin roles, account deletion now recursively removes all six user subcollections via a callable plus an Auth-trigger safety net, and both compile gates are clean — `tsc --noEmit` and ESLint report zero errors. Release signing was also fixed: an Android release build now refuses to build without a real keystore instead of silently signing with the debug key. Test count went from 5 thin suites (1 broken) to 11 suites / 136 passing tests, including Firestore rules tests against the emulator and Cloud Functions unit tests.

Two blockers remain, both operational rather than code-level: **there is still no CI/CD** (the newly green gates can silently regress again), and **the iOS app still carries the React Native example bundle identifier** with no signing team, which blocks any App Store submission and ripples into Firebase/OAuth configuration. Android is materially closer to shippable than iOS. The hardening backlog (App Check, fail-open storage contentType, npm advisories, crash reporting, staging environment, privacy store labels) is unchanged and should be treated as the next phase.

Estimated remaining effort: **2–4 days** to clear the two blockers; a further **1–2 weeks** for the high-severity hardening set.

Quality scorecard

Dimension	Score	Prev	Ship bar	Assessment
Feature completeness	78	78	70	Full learner + CMS loop implemented
Architecture	64	62	70	Notification helpers extracted & tested; fan-out scan remains
Security model	58	38	70	Rules now match UI matrix (tested); App Check & storage fail-open pending
Privacy / compliance	60	32	70	Recursive deletion + declared privacy manifest; PII cache & PDF leak remain
Code quality gates	85	28	70	tsc and ESLint clean; 5 benign warnings
Test coverage	68	22	70	136 tests incl. rules + Functions; no coverage thresholds or E2E
Release readiness	40	18	70	Android release signing enforced; iOS identity still example; minify off
Ops / observability	18	15	70	Still no CI, crash reporting, monitoring, or staging split
Documentation	28	25	70	README still boilerplate; About screen still a stub

1. Verified fixes since the previous audit

Each item below was re-verified against the current working tree, not just the commit messages.

FIXED SEC-01 **Firestore rules now enforce the admin/superadmin permission matrix**

The rules split cleanly: plain admins can write only the four delegated content types (`resourceNotes` , `assignments` , `exams` , `quizCompetitions` + their answer keys); `courses` , `notifications` , `schools` , `playlists` , app content, and events are superadmin-only. **Verified by 32 passing emulator tests**, including "admins cannot create courses (superadmin-only collection)", role self-escalation denials, and a default-deny test for unmatched paths.

Evidence: `firestore.rules` · `__tests__/rules/firestore.rules.test.js` — 32/32 pass against Firestore emulator, 17 Jul 2026

FIXED SEC-02 **Admin callables no longer reject superadmins**

`sendLiveNotification` and `resetUserQuizProgress` now use the shared `isAdminRole()` helper (accepts `admin` and `superadmin`), which is exported from `gradingHelpers.js` and unit-tested for all role values. Both features are usable again. One residual inconsistency is noted as SEC-07 below.

Evidence: `functions/index.js:90, 211` · `functions/gradingHelpers.js:8` · `functions/__tests__/gradingHelpers.test.js`

FIXED PRI-01 **Account deletion now removes all Firestore subcollections**

Two server-side mechanisms exist, exactly as recommended: a `deleteMyAccountData` callable (auth-checked, `recursiveDelete` on `users/{uid}`) invoked by `deleteAccountService.ts` before the Auth account is deleted, plus an `onAuthUserDeleted` v1 Auth trigger as a safety net covering `console/Admin-SDK` deletions. All six subcollections (`continueLearningProgress` , `examAttempts` , `quizAttempts` , `fcmTokens` , `notificationPreferences` , `notificationReads`) are covered by the recursive delete.

Evidence: `functions/index.js:259–283` · `src/services/firebase/deleteAccountService.ts:110–136`

FIXED QG-01 **TypeScript compiles cleanly**

`npx tsc --noEmit` exits 0. The 12 previous errors — including the ignored `initialState` navigation prop, the invalid `PhotoQuality` , and the missing `FirebaseServiceErrorCode` union members — are resolved.

Evidence: `npx tsc --noEmit` , exit 0, 17 Jul 2026

FIXED QG-02 **ESLint reports zero errors**

`npx eslint .` exits 0 with 0 errors. The hook-dependency runtime hazards (stale notification-send closure, identity-unstable memo inputs, missing exam effect dependency) are gone. Five warnings remain: four are `eslint-disable` comments inside generated `coverage/` artifacts (the folder should be ESLint-ignored) and one `no-void` in `functions/gradingHelpers.js:111`.

Evidence: `npx eslint .` — 0 errors / 5 warnings, 17 Jul 2026

FIXED QG-03 **Test suite rebuilt: 136 passing tests across app, Functions, and rules**

The previously broken `App.test.tsx` now passes via a proper `jest.setup.js` and hand-written mocks for every `@react-native-firebase/*` module and Google Sign-In. Current state: **8 app suites / 55 tests** (auth service, FCM token service, Google Sign-In, gamification, admin access matrix), **2 Functions suites / 49 tests** (grading + notification helpers, extracted into pure modules for testability), and **32 Firestore rules tests** run against the emulator via `npm run test:rules`. Remaining gaps are tracked as QG-04 (medium) below.

Evidence: Jest runs 17 Jul 2026 — app 55/55, functions 49/49, rules 32/32 (emulator)

FIXED REL-01 **Android release builds can no longer ship with the debug keystore**

The release `signingConfig` now reads from `android/keystore.properties` and throws a hard Gradle error with instructions if the file is missing — a release APK/AAB signed with the debug key is no longer possible.

Evidence: `android/app/build.gradle:96–115`

FIXED PRI-02a **iOS privacy manifest now declares collected data types**

`PrivacyInfo.xcprivacy` declares nine `NSPrivacyCollectedDataTypes` entries (previously: none), covering the identity, contact, photo, device-token, and product-interaction data the app actually collects. The remaining store-side work (App Store Connect labels, Play Data Safety form, privacy policy URL) is tracked as PRI-02b.

Evidence: `ios/Evolve/PrivacyInfo.xcprivacy` (9 collected-data entries)

2. Remaining release blockers

BLOCKER OPS-01 Still no CI/CD — the newly green gates are unprotected

Unchanged from the previous audit: no GitHub Actions, no Fastlane, no automated checks. The repo just demonstrated how quickly gates drift when nothing enforces them (12 tsc errors and 24 ESLint errors accumulated unnoticed). All four gate categories now pass locally — this is the cheapest possible moment to lock them in.

Evidence: no `.github/workflows/`, no Fastlane, no pipeline config, 17 Jul 2026

FIX

```
# .github/workflows/ci.yml — minimum viable gate (everything below passes today)
name: CI
on: [push, pull_request]
jobs:
  verify:
    runs-on: ubuntu-latest
    steps:
      - uses: actions/checkout@v4
      - uses: actions/setup-node@v4
        with: { node-version: 20, cache: npm }
      - uses: actions/setup-java@v4
        with: { distribution: temurin, java-version: 21 } # Firestore emulator
      - run: npm ci
      - run: npx tsc --noEmit
      - run: npx eslint . --max-warnings 0
      - run: npm test -- --ci
      - run: npm ci --prefix functions && npm test --prefix functions -- --ci
      - run: npm run test:rules
```

Note: `--max-warnings 0` requires first ignoring `coverage/` in ESLint config and resolving the one `no-void` warning (see LOW-08).

BLOCKER OPS-02 **iOS release identity is still the React Native example template**

Unchanged: `PRODUCT_BUNDLE_IDENTIFIER` is still `org.reactjs.native.example.Evolve` in both build configurations, and no `DEVELOPMENT_TEAM` is set. Apple rejects `example` bundle IDs, and the ID is baked into `GoogleService-Info.plist` and the Google Sign-In URL scheme — changing it late means re-issuing the Firebase iOS app and OAuth clients. This blocks iOS only; Android identity (`com.evolve`) is fine.

Evidence: `ios/Evolve.xcodeproj/project.pbxproj:294, 321`, 17 Jul 2026

FIX

1. Register `com.evolve` (matching Android) in the Apple Developer portal; set `PRODUCT_BUNDLE_IDENTIFIER` and `DEVELOPMENT_TEAM` in both Debug/Release configs.
2. Add an iOS app with that bundle ID in the Firebase console; replace `GoogleService-Info.plist`; update the reversed client ID URL scheme.
3. Create an iOS OAuth client for the new bundle ID; verify Google Sign-In end to end on a device.
4. Adopt a shared versioning scheme (marketing 1.0.0, build = CI run number) with Android `versionCode` / `versionName` (both still at initial values).

3. High severity

HIGH SEC-03 **No App Check, rate limiting, or abuse controls on callable Functions (unchanged)**

Any device with a valid Firebase Auth token can still invoke `submitExamAttempt`, `submitQuizAttempt`, and the admin callables at unlimited rate from outside the app. No `enforceAppCheck` on any callable, no per-user throttle.

Evidence: `functions/index.js` — no `enforceAppCheck` option on any of the 6 exported callables

FIX

Add `@react-native-firebase/app-check` (Play Integrity / App Attest) on the client; set `{ enforceAppCheck: true }` on callables; add a simple Firestore-count throttle inside the two submit callables (e.g. max 3 attempts/minute). Roll out in monitor-only mode first, then enforce; also enable App Check for Firestore and Storage in the console.

HIGHDEP-
01**npm advisories reduced but still present: app 20 (4 critical) · functions 11 (1 critical) (improved)**

App (`npm audit --omit=dev`): 4 critical / 3 high / 12 moderate / 1 low — all in the React Native CLI/Metro dev-tooling graph (`@react-native-community/cli` command injection, `fast-xml-parser` ×6, `shell-quote`, `ws`, `minimatch`, `picomatch`); none ship in the app binary, but they run on developer machines and CI. Functions: 1 critical (`websocket-driver`), 1 high (`form-data` CRLF injection), 9 moderate (mostly `uuid` / `protobufjs` via `firebase-admin`) — these *do* run in production.

Evidence: `npm audit --omit=dev` in both packages, 17 Jul 2026

FIX

Run `npm audit fix` (no `--force`) in both packages — it resolves `websocket-driver`, `form-data`, `shell-quote`, `ws`, `minimatch`, `picomatch`, and most moderates within `semver`. The remaining CLI/`fast-xml-parser` advisories clear with the next React Native / CLI upgrade; document them as accepted dev-tooling exceptions until then. Add `npm audit --omit=dev --audit-level=high` for `functions/` to CI.

HIGH

OPS-03

Single Firebase environment, no crash reporting, no monitoring (unchanged)

One Firebase project still serves development and future production; no Crashlytics, analytics, performance monitoring, or alerting. Post-launch crashes and Function failures would be invisible.

Evidence: `.firebaserc` (single project) · no crash/monitoring SDK in `package.json`

FIX

Create an `evolve-staging` Firebase project with aliases in `.firebaserc` and per-environment `google-services.json` /plist via build flavors; add `@react-native-firebase/crashlytics`; alert on Function error rate and p95 latency for the submit callables in Cloud Monitoring; deploy rules/Functions to staging first in CI.

4. Medium severity

MEDIUM

SEC-07

New: `sendLiveNotification` accepts plain admins while UI and rules say superadmin-only

The SEC-02 fix used `isAdminRole()` (admin or superadmin) for both repaired callables. For `resetUserQuizProgress` that may be intended, but live notifications are superadmin-only everywhere else: the Admin Notifications screen is superadmin-gated and the `notifications` collection rules allow superadmin writes only. A plain admin can bypass the UI and invoke the callable directly to push notifications to every user.

Evidence: `functions/index.js:90` (`isAdminRole`) vs. `firestore.rules:153–155` (superadmin-only) and the superadmin-only UI gate

FIX

```
// functions/index.js – align with the UI/rules matrix:
function isSuperAdminRole(role) { return role === 'superadmin'; }
// in sendLiveNotification:
if (!adminSnap.exists || !isSuperAdminRole(adminSnap.data().role)) {
  throw new HttpsError('permission-denied', 'Only superadmins can send live notifications.');
```

Decide explicitly per callable which roles qualify, and add a Functions test asserting a plain admin is denied.

MEDIUM

SEC-04

Storage rules still accept uploads with missing `contentType` (fail-open) (unchanged)

`storage.rules` still validates with `!('contentType' in request.resource) || request.resource.contentType.matches(...)` — an upload that omits `contentType` passes both the image and PDF checks.

Evidence: `storage.rules:114–120`

FIX

```
allow write: if request.resource.contentType != null
  && request.resource.contentType.matches('image/(jpeg|png|webp)')
  && request.resource.size < 5 * 1024 * 1024;
```


MEDIUM

SEC-05

One-time migration function `migrateAnswerKeys` remains deployed (unchanged)

Still exported at `functions/index.js:477`; a standing admin-callable full-collection write primitive with no remaining purpose.

Evidence: `functions/index.js:477`

FIX

Delete the export and redeploy (`firebase deploy --only functions` removes unlisted functions after confirmation). Keep the code in `scripts/` run locally with a service account if migrations may recur.

MEDIUM

SEC-06

Any authenticated user can read any user's profile image (unchanged)

`profileImages/` reads still require authentication only. Writes/deletes are correctly owner-scoped by filename, but reads are not.

Evidence: `storage.rules:27-28` (`allow read: if isAuthenticated()`)

FIX

If photos are owner-only, add `imageFile.matches('^' + request.auth.uid + '\\.\\.\\.')` to the read rule. If they appear on shared surfaces, keep authenticated read but document it in the privacy policy.

MEDIUM

PRI-03

PII and role cached unencrypted in AsyncStorage (unchanged)

`profileCache.ts` still stores name, email, phone, school, grade, track, and role in plain AsyncStorage.

Evidence: `src/services/profileCache.ts:78-107`

FIX

Move to `react-native-keychain` /encrypted MMKV, or trim cached fields to non-PII; re-read the profile on app foreground and admin-screen entry for role freshness.

MEDIUM

PRI-04

PDFs still leak tokenized URLs to Google Docs Viewer (unchanged)

`pdfViewerUrl.ts` still wraps Firebase Storage download URLs (embedding access tokens) in `docs.google.com/gview`; the WebView has no origin allowlist.

Evidence: `src/utils/resources/pdfViewerUrl.ts:4`

FIX

Render natively with `react-native-pdf`, or at minimum add `originWhitelist` + `onShouldStartLoadWithRequest` restricted to `firebasestorage.googleapis.com`.

MEDIUMARC-
01**Notification fan-out still scans every user; dead tokens never cleaned up (partially improved)**

The fan-out logic was extracted into `notificationHelpers.js` with 49 unit tests and batched multicast sends — a real improvement in correctness and testability. But each send still runs full `collectionGroup` scans of `notificationPreferences` and `fcmTokens`, and `sendMulticastBatches` counts failures without deleting tokens that return `registration-token-not-registered`.

Evidence: `functions/index.js:38, 140` · `functions/notificationHelpers.js:205–220`

FIX

Short term: inspect per-token responses in `sendMulticastBatches` and delete dead token docs.

Medium term: switch to FCM topics (`school_{id}` , `category_{name}`) to eliminate the scans.

MEDIUMOPS-
04**Build hygiene: dual lockfiles, floating androidx version, minification off (signing fixed; rest unchanged)**

Release signing is fixed (REL-01), but `package-lock.json` and `yarn.lock` are both still committed, `androidx.activity:activity:1.9.+` still floats, and `enableProguardInReleaseBuilds` is still `false` — release builds ship unminified.

Evidence: repo root lockfiles · `android/app/build.gradle:62, 132`

FIX

Pick npm, delete `yarn.lock`, gitignore it. Pin `androidx.activity:activity:1.9.3`. Enable `minifyEnabled true` + `shrinkResources true` with RNFirebase/Reanimated keep rules and verify a release build on-device.

MEDIUM

DOC-01

Documentation still boilerplate; About screen still a stub (unchanged)

`README.md` remains template content plus auth notes; `AboutScreen.tsx` is still 12 lines rendering the word "About".

Evidence: `README.md` · `src/presentation/screens/About/AboutScreen.tsx` (12 lines)

FIX

Write a real README (setup, environments, role bootstrap, deploy commands) and a short operations runbook. Finish the About screen (version, licenses, privacy policy link) or remove it from navigation before store review.

MEDIUMQG-
04**Remaining test gaps: no coverage thresholds, no Functions integration tests, no E2E**

The rebuilt suite is unit-level. There are no coverage thresholds (`collectCoverageFrom` exists but nothing fails on regression), the exported callables themselves (role checks, throttles once added) have no integration tests — only their extracted helpers do — and there is no E2E smoke coverage. Also note: `npm run test:rules` requires JDK 21+ with the globally installed `firebase-tools` 15 (this machine has JDK 17; the audit ran the suite via `npx firebase-tools@13`).

Evidence: `jest.config.js` (no `coverageThreshold`) · rules run required `firebase-tools@13` fallback, 17 Jul 2026

FIX

Add a `coverageThreshold` baseline; add callable-level tests with `firebase-functions-test` (assert role denials incl. SEC-07); pin a JDK 21 requirement in the README/CI so `test:rules` is reproducible; schedule Maestro/Detox smoke tests post-launch.

5. Low severity & hygiene

LOW ARC-02 **YouTube API key embedded in the client binary (unchanged)**

Restrict the key in Google Cloud Console (YouTube Data API only, bound to Android package + SHA-1 and iOS bundle ID) and set a daily quota cap.

LOW ARC-03 **Committed generated iOS artifacts (`ios/.tmp/`) (unchanged, downgraded)**

`git rm -r --cached ios/.tmp`, gitignore it, and let codegen regenerate.

LOW PRI-02b **Store-side privacy work still pending (manifest itself is fixed)**

Mirror the new `PrivacyInfo.xcprivacy` declarations in App Store Connect privacy labels and the Play Data Safety form; publish a privacy policy URL (required by both stores) documenting the now-correct deletion behavior. Given the kids track, have counsel review COPPA/GDPR-K obligations.

LOW MISC-01 **Placeholder remote assets in production UI (unchanged)**

`randomuser.me` default avatar still referenced in `profileDefaults.ts`. Bundle defaults locally.

LOW MISC-03 **Package scripts improved but no `typecheck / verify` gate (partially improved)**

`test:functions` and `test:rules` scripts were added. Still missing: `"typecheck": "tsc --noEmit"` and a combined `"verify"` script for local pre-push use.

LOW MISC-04 **No startup validation of required configuration (unchanged)**

Add a dev-build `assertConfig()` at bootstrap and a CI check of `.env` keys against `.env.example`.

LOW MISC-05/06 **Firebase key restrictions unverified · iOS still allows landscape (unchanged)**

Restrict the auto-created API keys by app + API in Google Cloud Console. `Info.plist` still lists portrait + both landscapes; lock to portrait except video playback.

LOW LOW-08 **New: 5 residual ESLint warnings block a `--max-warnings 0` CI gate**

Four come from linting the generated `coverage/` folder; one is `no-void` in `functions/gradingHelpers.js:111`. Add `coverage/` to `.eslintignore` (or `ignorePatterns`) and replace the `void` expression, then CI can enforce zero warnings.

6. Remediation roadmap

Phase 0 — Unblock (2–4 days) · OPS-01, OPS-02, SEC-07, LOW-08

1. Land the CI workflow while every gate is green (OPS-01). Fix the 5 ESLint warnings first (LOW-08) so `--max-warnings 0` passes.
2. Tighten `sendLiveNotification` to superadmin-only to match UI and rules (SEC-07); add the role-denial test; redeploy Functions.
3. Set the production iOS bundle ID, team, Firebase iOS app, and OAuth client (OPS-02) — required for iOS only.

Phase 1 — Harden (1–2 weeks) · SEC-03/04/05/06, DEP-01, PRI-02b/03/04, OPS-03/04, QG-04, DOC-01

1. `npm audit fix` in both packages; add audit gate for `functions/` to CI; document accepted dev-tooling exceptions.
2. App Check in monitor mode → enforce; per-user throttles on the submit callables.
3. Fail-closed Storage `contentType`; scope profile-image reads; remove `migrateAnswerKeys`.
4. Store privacy labels + privacy policy URL; encrypted profile cache; native PDF rendering.
5. Staging Firebase project + Crashlytics + Function alerting; single lockfile, pinned androidx, minified release build verified on-device.
6. Coverage thresholds + callable-level Functions tests; real README + runbook; finish or hide the About screen.

Phase 2 — Operate (post-launch)

1. FCM topic-based fan-out and dead-token cleanup (ARC-01).
2. E2E smoke tests (Maestro/Detox); Fastlane store delivery.
3. Remote Config for support contact and feature toggles; planned React Native upgrade window (also clears remaining CLI advisories).

7. Ship gate checklist

Gate	Criterion	Status today
Compile	<code>tsc --noEmit</code> and <code>eslint . --max-warnings 0</code> pass in CI	Passes locally (5 warnings); no CI
Tests	All Jest suites green; rules tests cover the admin permission matrix	136/136 pass incl. 32 rules tests
Authorization	Plain admin cannot write non-delegated collections; role checks consistent across UI, rules, and Functions	Rules verified; SEC-07 callable mismatch open
Privacy	Deletion leaves zero user documents; manifest & store labels match; privacy policy live	Deletion + manifest done; store labels/policy pending

Dependencies	No unresolved critical/high advisories in <code>npm audit --omit=dev</code>	App 4 crit (dev-tooling) · Functions 1 crit/1 high
Identity	Production bundle IDs on both platforms; release signing verified	Android done; iOS bundle ID still example
Ops	Crashlytics from a release build; staging receives deploys before production	Not started

Evolve deployment readiness re-audit · generated 17 July 2026 at commit `cd3353e` (+ uncommitted test/mock additions) · gates executed locally: tsc, ESLint, Jest (app 55, functions 49), Firestore rules tests via emulator (32, run with firebase-tools 13 due to local JDK 17), npm audit (app + functions) · supersedes the pre-remediation report of the same date · this is not a penetration test and no live production Firebase project was probed.